

A Robust Privacy-Preserving Federated Learning Model Against Model Poisoning Attacks

Abbas Yazdinejad^{ID}, Ali Dehghantanha^{ID}, Hadis Karimipour^{ID}, Gautam Srivastava^{ID}, *Senior Member, IEEE*,
and Reza M. Parizi^{ID}, *Senior Member, IEEE*

Abstract—Although federated learning offers a level of privacy by aggregating user data without direct access, it remains inherently vulnerable to various attacks, including poisoning attacks where malicious actors submit gradients that reduce model accuracy. In addressing model poisoning attacks, existing defense strategies primarily concentrate on detecting suspicious local gradients over plaintext. However, detecting non-independent and identically distributed encrypted gradients poses significant challenges for existing methods. Moreover, tackling computational complexity and communication overhead becomes crucial in privacy-preserving federated learning, particularly in the context of encrypted gradients. To address these concerns, we propose a robust privacy-preserving federated learning model resilient against model poisoning attacks without sacrificing accuracy. Our approach introduces an internal auditor that evaluates encrypted gradient similarity and distribution to differentiate between benign and malicious gradients, employing a Gaussian Mixture Model and Mahalanobis Distance for byzantine-tolerant aggregation. The proposed model utilizes Additive Homomorphic Encryption to ensure confidentiality while minimizing computational and communication overhead. Our model demonstrates superior performance in accuracy and privacy compared to existing strategies and encryption techniques, such as Fully Homomorphic Encryption and Two-Trapdoor Homomorphic Encryption. The proposed model effectively addresses the challenge of detecting maliciously encrypted non-independent and identically distributed gradients with low computational and communication overhead.

Index Terms—Privacy-preserving, FL, model poisoning, homomorphic encryption.

I. INTRODUCTION

PRVACY preservation is a critical concern in today's digital landscape, particularly in the realm of machine

learning (ML) and deep learning (DL). Federated learning (FL) is a popular PP solution for ML and DL models because it allows users to share model parameters with a server instead of sharing private data [1]. However, while FL presents a complete collaborative ML solution, it falls short of being fully privacy-preserving (PP). For example, adversaries can still retrieve sensitive data through shared gradients and global parameters [2]. Privacy-preserving federated learning (PPFL) solutions utilize cryptographic primitives for secure data encryption to ensure the confidentiality of transmitted data, and secure aggregation to reduce the inherent privacy risks associated with aggregation processes [3], [4]. It is important to acknowledge, however, that these measures do not entirely eliminate the potential for privacy attacks on the global model, such as inference attacks. Additionally, challenges like the opacity of local training in PPFL models can render them vulnerable to model poisoning attacks [5].

Among the different types of attacks in the FL setup, model poisoning stands out as having the most significant impact on the accuracy of the federated model [3], [6]. Model poisoning adversaries manipulate user input by submitting poisonous updates to local models to create arbitrary deviance from correct trends [3]. Furthermore, model poisoning attacks have the potential to significantly impair the performance of FL systems by compromising the accuracy of the federated model and leading to erroneous decisions. To manipulate the convergence direction of the aggregated gradient, certain malicious users may introduce poisonous local gradients that deviate from their benign counterparts [6]. The primary objectives of these attackers include causing the federated model to generate labeled samples of their choice (referred to as targeted attacks) or indiscriminately misclassifying all samples (termed untargeted attacks) [7]. Moreover, these attacks often manifest in scenarios where malicious participants manipulate the training process by injecting harmful updates [8].

Current research has explored various defence mechanisms against model poisoning attacks in PPFL [8], [9]. However, these approaches still face significant challenges, including: **Private Information Leakage:** defence strategies in PPFL, designed to counter model poisoning, inadvertently undermine privacy. These strategies often require access to local gradients, causing potential information leakage [10]. **Inefficiency Against Encrypted Model Poisoning Attacks:** PPFL struggles to detect concealed poisoning attacks due to the obfuscation provided by cryptographic primitives. Existing defences often overlook the potential for maliciously encrypted

Manuscript received 13 December 2023; revised 26 April 2024; accepted 28 May 2024. Date of publication 27 June 2024; date of current version 10 July 2024. The associate editor coordinating the review of this article and approving it for publication was Dr. Alptekin Küpçü. (*Corresponding author: Ali Dehghantanha.*)

Abbas Yazdinejad and Ali Dehghantanha are with the Cyber Science Lab, Canada Cyber Foundry, University of Guelph, Guelph, ON N1G 2W1, Canada (e-mail: ayazdine@uoguelph.ca; adeghghan@uoguelph.ca).

Hadis Karimipour is with the School of Engineering, Department of Electrical and Software Engineering, University of Calgary, Calgary, AB T2N 1N4, Canada (e-mail: hadis.karimipour@ucalgary.ca).

Gautam Srivastava is with the Department of Mathematics and Computer Science, Brandon University, Brandon, MB R7A 6A9, Canada, also with the Research Centre for Interneural Computing, China Medical University, Taichung 40402, Taiwan, and also with the Department of Computer Science and Mathematics, Lebanese American University, Beirut 1102, Lebanon (e-mail: srivastavag@brandonu.ca).

Reza M. Parizi is with the Decentralized Science Lab, Kennesaw State University, Kennesaw, GA 30144 USA (e-mail: rparizi1@kennesaw.edu).

Digital Object Identifier 10.1109/TIFS.2024.3420126

1556-6021 © 2024 IEEE. Personal use is permitted, but republication/redistribution requires IEEE permission.
See <https://www.ieee.org/publications/rights/index.html> for more information.

gradients. **Data Heterogeneity and Unpredictability:** The co-existence of Independent and Identically Distributed (IID) and Non-Independent and Identically Distributed (non-IID) data typifies data heterogeneity in PPFL, introducing significant challenges [6]. Non-IID data, in particular, leads to significant local biases and complicates the detection of poisonous gradients. This variance underscores the inadequacy of current defence mechanisms and highlights the necessity for tailored strategies to manage diverse data environments effectively. **Cryptography Performance Efficiency:** The efficiency of cryptographic models, fundamental to FL overhead, is often a focal point in current defenses. This includes secure multi-party computation (SMC), Fully Homomorphic Encryption (FHE), and Differential Privacy (DP) [11], [12]. FHE and SMC can lead to high computational costs, while DP may sacrifice accuracy [12]. In response, recent studies in PPFL have been integrating these techniques, employing DP for user-level privacy [13], SMC for secure model aggregation, and HE for encrypted computation [14], [15]. Evaluating cryptographic operations in PPFL requires a balance of security and privacy with computational and communication costs, a balance crucial for maintaining functional, secure, and efficient PPFL systems [12], [16].

In addition to its role in computational efficiency, Homomorphic Encryption (HE) is particularly crucial in defending the entire FL pipeline against a variety of attacks [17]. Common vulnerabilities in FL, such as model poisoning attacks, where malicious actors manipulate training data to corrupt the model, and inference attacks, which aim to deduce sensitive information from model outputs, necessitate robust defense mechanisms [6]. HE offers a comprehensive solution that goes beyond secure aggregation. By enabling computations on encrypted data, HE protects data privacy throughout the entire learning process — from initial data transmission to final model aggregation. This ensures that the privacy and integrity of data are maintained at every stage of the FL pipeline, making it a more complete solution compared to methods that focus solely on secure aggregation.

Existing works such as TrustFL [18] and SafeFL [19] provide foundational defence against model poisoning attacks, but they have limitations. TrustFL's reliance on Trusted Execution Environments (TEE) limits scalability and hardware compatibility. Furthermore, SafeFL's use of SMC leads to high computational overhead, making it less viable for large-scale applications. Our approach, in contrast, focuses on encrypted gradients in both IID and non-IID settings, offering a solution that is novel, more efficient, and scalable. This differentiates our work from existing methods and fills a significant gap in PPFL research. Our model's emphasis on encrypted gradient analysis presents a versatile and practical defence against model poisoning, aligning with the needs of real-world applications prioritizing efficiency and data confidentiality. In response to these challenges, we introduce a novel PPFL model tailored to counteract model-poisoning adversaries. The primary contributions of this work can be summarized as follows:

- To prevent privacy leaks, in this paper, we design and implement a novel PPFL architecture that employs

Additive Homomorphic Encryption (AHE) to ensure data confidentiality. Our proposed PPFL model utilizes the Paillier cryptosystem to provide additive homomorphic encryption for working on encrypted gradients against model poisoning attacks while preserving user, server, and gradient privacy. This encryption is specifically chosen for its balance between maintaining data confidentiality and computational efficiency, addressing both direct data leakage and potential inference attacks.

- To address inefficacy related to encrypted model poisoning, our model integrates an internal auditor mechanism, significantly boosting accuracy in detecting and preventing such attacks. This hallmark feature of our PPFL model consistently monitors and counteracts malicious activities on encrypted local gradients. Utilizing AHE, our system conducts mathematical operations on encrypted data, maintaining its security. This enables the auditor to detect poisoning efforts by analyzing gradient patterns using statistical tools like mean and covariance matrix calculations on encrypted gradients. Our approach effectively addresses the challenges of encrypted model poisoning, adeptly managing varied local gradient distributions. Moreover, it reduces the risk of misidentifying benign gradients as harmful, streamlining the process of predicting and preventing poisonous gradients. The auditor's operation on encrypted data extends the PP measures beyond the aggregation phase, enhancing overall privacy in the FL process.

- To improve robustness in PPFL, particularly amidst data heterogeneity (IID and non-IID), varying numbers of users, and diverse attack rates (10% to 50%) in both targeted and untargeted attacks, we introduce an innovative auditing protocol. This protocol is tailored not only to address the challenges of heterogeneous data but also to effectively counteract the impact of a variable proportion of malicious users during model poisoning attack mitigation. Employing the Gaussian Mixture Model (GMM) and Mahalanobis distance (MD), our approach facilitates Byzantine-tolerant gradient aggregation within PPFL. This advanced strategy provides a comprehensive and robust solution for managing heterogeneous data and mitigating risks posed by targeted and untargeted attacks, ensuring resilience even in scenarios infiltrated by malicious users.

- To enhance the efficiency of cryptographic performance, we introduced optimization techniques in the PPFL. These techniques minimize communication and computation overheads while mitigating model poisoning attacks. Our innovations focus on eliminating redundancies, reducing the number of communication rounds, and cutting computational costs. When faced with model poisoning attacks, these improvements directly enhance the efficiency of the PPFL in terms of operation times, key sizes, and memory consumption. We conducted a comprehensive security analysis and system overhead evaluation to validate the model's effectiveness and privacy-preserving capabilities.

- We formulated an efficiency score for the proposed PPFL model, integrating performance and privacy metrics like computational efficiency, accuracy, and privacy. This offers a coherent trade-off perspective when incorporating

PP techniques into FL, underscoring the balance between privacy and performance in PPFL. Finally, our comprehensive security analysis and practical evaluation against poisoning attacks extend beyond common cryptographic techniques, such as FHE and Two-Trapdoor Homomorphic Encryption (THE). Together, these elements represent a pioneering approach distinct from and superior to existing defensive strategies against model poisoning attacks. This innovation marks a significant leap forward, shedding new light on both the theoretical understanding and practical application of privacy and security within FL.

This paper proceeds as follows: Section II reviews related literature. Section III outlines the threat models and problem formulation. Our robust PPFL model is presented in Section V. Sections VI cover security and theoretical analyses, and Sections VII address the experimental results of the proposed model. Finally, Section VIII concludes with future prospects.

II. RELATED WORK

Existing studies in PPFL focus on enhancing privacy using cryptographic methods such as SMC, DP, and HE. Abadi et al. [20] used a homomorphic encryption system based on learning with errors to protect shared local gradients in DL systems. Zhao et al. [12] proposed SecProbe, an approach to preserve privacy and reduce the impact of poor data quality users on model accuracy. Another work proposed Privacy-Preserving Federated Deep Learning (PPFDL) [21], addressing the data quality of users and mitigating the adverse effects of users with low data quality. Complementing these, RoFL [22] introduced a solution focusing on the robustness of FL, particularly targeting attacks and addressing non-IID data challenges. However, most FL research overlooks the security threat from malicious users [23]. The focus often remains on PP and training encrypted data, neglecting real-world challenges like model poisoning and gradient collection difficulties due to data heterogeneity [4], [24]. Despite FL participants retaining their data locally, adversaries can compromise model integrity and data privacy during training [10], [25].

SecureML [26] offers a notable foundation in PPML, leveraging multi-party computation and HE for secure data analysis. This framework is particularly relevant to our work due to its integration of HE, which is similar to our approach in FL. However, our model uniquely addresses the specific challenges of FL, such as model poisoning and data decentralization, while focusing on the efficiency and scalability aspects of HE in this context. In another contribution, [27] research on decentralized FL emphasizes PP in dynamic communication networks. Their approach, dealing with time-varying communication graphs, aligns with our emphasis on encrypted gradients and robustness in FL. Our work builds on this by tackling model poisoning threats and maintaining data privacy and model integrity in fluctuating network conditions, thus contributing to the evolving discourse on secure and efficient FL methodologies.

Model poisoning attacks involve corrupting locally-trained model parameters to taint the aggregation process [7]. These attacks have impeded the advancement of PPFL [28], [29], introducing encrypted poisonous updates rather than poisonous

samples, making them more clandestine and potent [28], [29]. ShieldFL [6] mitigates model poisoning attacks in PPFL, offering Byzantine-tolerance aggregation using Cosine Similarity (CS) for both IID and non-IID data. In secure aggregation protocols, ACORN [30] stands out by enhancing the computational efficiency of FL. Additionally, ELSA [31], as a secure aggregation model for FL, directly addresses the challenge of malicious actors. It builds upon and extends the principles established in Prio+ [32], focusing on efficiency and the core integration of mechanisms to handle malicious participants in its design. Prio+, a novel approach in PP aggregate statistics, utilizes Boolean secret-sharing instead of zero-knowledge proofs to ensure data correctness in FL. However, these works do not address cryptographic efficiency in the context of PPFL. Several approaches have been proposed to mitigate poisoning attacks in the FL paradigm [5], [10], [24], [33]. The Median-based defence technique [10], Krum [10], Bulyan [24], Auror [33], and Sybils [5] have been proposed to detect outliers and generate global gradients, but they lack Byzantine tolerance mechanism and fail when faced with heterogeneous data in FL. FL-trust [34] offers Byzantine-tolerant mechanisms in PPFL to mitigate model poisoning. It uses a server-held validation dataset, detecting anomalies by comparing local gradients' CS with benign gradients. Current strategies, however, struggle to effectively defend against encrypted model poisoning in both IID and non-IID data scenarios. This challenge is further compounded by the difficulty in distinguishing legitimate data contributions from malicious ones, especially when data is encrypted for privacy preservation. They often fail to harmonize privacy with security, overlook computational costs, and inadequately identify outliers in encrypted gradients, highlighting the need for more efficient approaches in PPFL. Our model tackles these challenges through a balanced approach that harmonizes privacy and security. By using AHE, we protect data confidentiality and enable secure computations on encrypted gradients. Simultaneously, our internal auditor, employing advanced statistical methods, adeptly identifies outliers, catering to both IID and non-IID scenarios without excessive computational burden. This synergy of privacy, security, and efficiency highlights the innovative edge of our model in PPFL.

III. PROBLEM FORMULATION

In PPFL models, a key focus is on securing the entire FL pipeline. This includes secure aggregation of model updates, where users contribute encrypted gradients to the FL server. These encrypted gradients enhance data privacy by protecting individual contributions from external adversaries and even the server itself. Secure aggregation in PPFL is distinct from simply sending encrypted gradients; it involves combining these gradients in a manner that prevents revealing individual updates while still facilitating effective global model training. Given N clients (N denotes the total number of clients) with a dataset D_i that could include IID or non-IID data distribution, the goal is to collaboratively train a global model M by minimizing loss function L , while ensuring data privacy and robustness against adversarial attacks while minimizing required computational resources. We aim to create a secure

PPFL framework F that: 1- Accounts for both IID and non-IID data distributions among clients; 2- Ensures data privacy by enabling user contribution to M without revealing individual data; 3- Checks encrypted gradients g_i for malicious attacks, with $g_i = \nabla(D_i, M)$; 4- Implements secure aggregation to combine verified gradients to ensure model robustness against poisoning attacks; 5- Ensures M performs well for all clients, regardless of data distribution scenarios; 6- Minimizes encryption and gradient verification overhead while optimizing cryptographic performance. The problem of adversarial attacks in PPFL can be expressed as minimizing $L(M)$ under constraints related to privacy, robustness, and efficiency, as shown in Eq. 1.

$$\text{minimize}_L(M) = \left(\frac{1}{N}\right) \times \sum_i^N L(D_i, M) \quad (1)$$

When minimizing Eq. 1, it is important to consider the following constraints: 1- After the gradients, denoted by g , are computed, the M is updated using the verified gradients, denoted by g_i . 2- $g_i = \nabla(D_i, M)$ for $i = 1, \dots, N$ where the gradients are encrypted to maintain confidentiality; 3- A number of performance constraints are satisfied, including those related to data security, the robustness of the model, the adaptation to IID and non-IID data distributions, and the efficiency of cryptographic calculations.

The gradients will be verified using a predefined verification function denoted by V_a in Eq. 2.

$$V_a(g_i) = \begin{cases} \text{benign} & \text{if } g_i \in \text{non-malicious} \\ \text{malicious} & \text{otherwise} \end{cases} \quad (2)$$

Eq. 2 describes the $V_a(g_i)$ function, crucial for secure aggregation in our PPFL model. It determines if an encrypted gradient g_i is benign or malicious, vital for safeguarding the FL process against adversarial attacks. This function evaluates g_i against expected non-malicious patterns, categorizing it accordingly. Such a mechanism ensures only valid gradients contribute to updating the global model M , thus enhancing its accuracy and resilience in adversarial PPFL scenarios. Based on Eq. 2, the benign gradients are passed to the global model: $M = M - \eta \times \left(\frac{1}{N}\right) \times \sum_1^N V_a(g_i) \times g_i$, where η is the learning rate. Assessing cryptographic efficiency in the FL framework, F considers accuracy, computation time, communication cost, and resource utilization as crucial for real-world practicality and efficiency.

A. Threat Model

This paper focuses on security and privacy threats in FL that are exploitable by malicious users. Similar to [2], [3], [6], and [34], we categorize users as benign or malicious, with poisoners potentially accessing varied local datasets. While aware of advanced adaptive poisoning attacks, our study concentrates on conventional model poisoning threats for consistent comparison. We explicitly assume non-collusion among users. This scope does not consider user-user collusion. Complex scenarios like servers colluding with clients or sophisticated adaptive attacks are also outside the scope of this work. This limitation ensures a fair comparison with [3], [6],

[7], [10], and [33], but also sets the stage for future research to extend our model to these more intricate threats, including various collusion scenarios and auditor threats. **Benign Users:** A user i is considered benign if and only if i truthfully provides local gradients g_i , with g_i serving as an unbiased estimator of the authentic gradient, trained on the user's local dataset D_i . **Malicious Users:** User j is deemed malicious if and only if j is controlled by a Byzantine adversary who orchestrates a model poisoning attack by submitting encrypted malicious gradients g_i^* . **Model Poisoning Attack:** When a user intentionally alters or fabricates gradients to weaken the global model's performance, functionality, or integrity, this is known as a model poisoning attack.

1) *Threat 1: The honest-but-curious (HBC) adversary:* In FL, the server, privy to all local gradients and ciphertexts, can act adversarially. The system operates on the assumption of this HBC behavior, but the server could potentially launch privacy attacks, including inferring the data privacy of users. The core threat lies in adversaries seeking sensitive global model information through data reconstruction or inference attacks. **Goal 1:** Protect local gradients' confidentiality. Adversaries, like servers, can expose sensitive user data through shared gradients and global parameters. Encrypting individual gradients before server transmission provides some degree of confidentiality.

2) *Threat 2: Inject poisonous gradients:* Byzantine actors can disrupt FL systems by submitting fraudulent gradients under the guise of heterogeneous data-derived gradients, thereby compromising model integrity. **Goal 2:** Improve the scrutiny of encrypted gradients to differentiate between benign and malicious users, bolstering the system's resilience against poisoning attacks.

B. Design Goals

This work aspires to innovate PPFL by formulating unique design goals with high accuracy, robustness, privacy, and computational efficiency, even amidst adversarial disruptions during training. **1- Accuracy:** We aim to ensure reliable output despite adversarial challenges during training, striking a balance between accuracy, robustness, privacy, and computational efficiency in PPFL. To operationalize this balance, we introduce specific metrics for each aspect. Classification accuracy measures the accuracy; resilience to defined poisoning attacks gauges robustness; the degree of data confidentiality assesses privacy; and time complexity and resource utilization metrics determine computational efficiency. This approach entails a detailed analysis of the trade-offs inherent in optimizing these aspects, supported by empirical evidence to demonstrate effective management, ensuring no aspect is significantly compromised. **2- Robustness:** We introduce a revolutionary concept of robustness in PPFL models, where the model should consistently deliver accurate output to all users, irrespective of any disruptive actions by adversaries, across both IID and non-IID contexts. This approach propels FL to new dimensions of reliability and consistency. **3- Privacy:** To safeguard users' data privacy, we address the potential of adversaries uncovering sensitive information, such as training samples or memberships, from shared gradients. Our focus is

on maintaining the confidentiality of each user's local gradients. **4- Computational efficiency:** Optimizing performance and minimizing costs is crucial in an FL environment. Our model addresses the challenge of malicious users who can significantly increase overhead and adversely impact computational efficiency. Additionally, we elaborate on the adaptability and scalability of our model, emphasizing how it can be configured for different systems and applications, thereby underlining its flexibility in diverse real-world scenarios.

IV. PRELIMINARIES

A. Gaussian Mixture Models

GMMs, a type of statistical model, are used to represent a dataset as a blend of multiple Gaussian distributions, each with its own mean and variance. These models excel in scenarios where the data is assumed to be generated from several Gaussian sources [35]. In the context of our PPFL model, GMMs provide a sophisticated method for analyzing the heterogeneous nature of gradient distributions, enabling us to categorize gradients into distinct clusters. This categorization is particularly useful for differentiating benign gradients, which typically align with the model's learning objective, from adversarial ones that attempt to skew the model's performance.

B. Mahalanobis Distance

MD is a multi-dimensional metric that measures the distance between a point and a distribution. Unlike Euclidean distance, MD is scale-invariant and takes into account the correlations of the data set [36]. In our model, MD is utilized as a robust tool for outlier detection in gradient distributions. It gauges how far a given gradient deviates from the expected distribution, thus effectively identifying gradients that are anomalous or likely to be the result of malicious activities. This makes MD especially suitable for ensuring the integrity of the learning process in PPFL, where gradient data can be diverse and influenced by various sources.

C. Cosine Similarity

CS measures the cosine of the angle between two vectors, useful in certain contexts but limited in handling high-dimensional, complex data, especially in multimodal distributions [37]. It may not fully represent the intricacies of such data due to its focus on vector direction alone. Conversely, MD accounts for the variance in each data dimension, offering a more detailed similarity measure for complex scenarios. MD's incorporation of the data's covariance structure renders it more effective in our PPFL model. This capability is essential in distinguishing malicious from benign gradients, crucial for robust performance, and effective outlier detection in federated learning, especially when adversarial inputs are present.

D. Additive Homomorphic Encryption

AHE is a form of encryption that allows specific types of computations to be carried out on ciphertexts and generate an encrypted result that, when decrypted, matches the result of operations performed on the plaintexts. This property is pivotal in contexts where privacy must be preserved during the

computation process [38]. In our model, AHE plays a critical role by enabling secure and private aggregation of encrypted data, such as gradients in FL, without revealing sensitive information. This capability is essential for maintaining data confidentiality while allowing the collective development of the model. AHE's relevance in our framework lies in its efficient handling of additive operations, which are fundamental in the gradient aggregation process, thus ensuring both data privacy and integrity without compromising the model's performance.

E. Types of Model Poisoning Attacks in Federated Learning

In FL, model poisoning attacks are a significant threat, mainly manifesting in two forms: **1- Targeted Attacks:** In these attacks, adversaries craft their actions to manipulate the model into misclassifying specific data points. They generate poisoned gradients that deliberately maximize the objective function related to these data points. This type of attack is particularly insidious as it aims to skew the model's predictions or classifications in a precise, controlled manner, targeting specific aspects of the model's functionality. **2- Untargeted Attacks:** Contrary to the focused nature of targeted attacks, untargeted attacks involve a more generalized approach to disrupting the model. Adversaries randomly re-label local training samples, leading to the creation of poisonous gradients. These gradients introduce noise and instability into the model, degrading its overall performance. Unlike targeted attacks, untargeted attacks aim to reduce the model's reliability and accuracy broadly, affecting its performance across various tasks.

V. PROPOSED MODEL

Fig. 1 shows the architecture and elements of the proposed model, made up of the fundamental entities: **1- Data Owners:** Also known as users, they collaborate under the service provider's tutelage to formulate a coherent model. Each user executes model training locally and forwards encrypted gradients to the service provider. It's presupposed that all data proprietors possess heterogeneous data. **2- Auditing Entity:** This is a trusted, autonomous unit responsible for managing the creation, distribution, and maintenance of public and private keys represented by (pk, sk) . These keys are vital for data encryption or ciphertext decryption. The auditing entity plays a pivotal role in verifying all gradients received before aggregation, distinguishing between benign and malicious gradients to foster a robust model resistant to malicious user actions. In line with the approach in [2], we consider the auditor a Trusted Authority, ensuring trustworthiness and independence from other entities. To address potential risks associated with this auditor being a single failure point and further enhance system reliability, we have integrated redundancy into the auditing process, as suggested in [39]. This redundancy is achieved through multiple independent auditors or a consensus-based approach among several auditors. In the independent auditor model, each auditor operates autonomously, providing a layer of security and reliability. Alternatively, the consensus-based model involves collaborative decision-making, requiring collective agreement among auditors to validate gradients. This

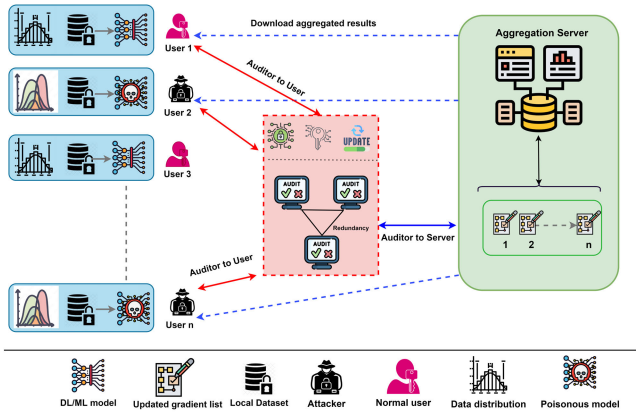


Fig. 1. Architecture of the proposed model.

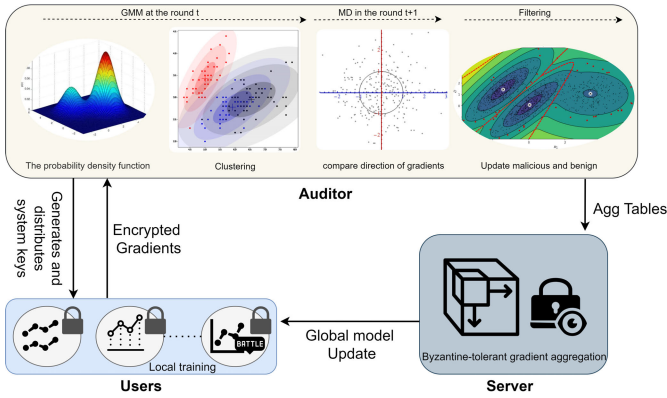


Fig. 2. Technical synopsis of the proposed system model.

design not only mitigates the risk of a single point of failure but also strengthens the overall system reliability and integrity, as emphasized in [39]. It ensures robust operation even if one auditor is compromised or fails, enhancing the system's resilience, especially in resisting model poisoning attacks. **3-Aggregation Server:** Upon deploying PP defence strategies and model poisoning resistance via the audit protocol, the aggregation server accrues user gradients. These gradients are aggregated to yield an optimized global model.

Fig. 2 presents a technical overview of the proposed model, incorporating internal auditing to detect malicious gradients among encrypted gradients on the server side. The auditor houses the local model m_i and the global model M as vector entities. Since locally-submitted gradients form multi-dimensional vectors, outlier detection is possible by employing the GMM to differentiate authentic and adversarial gradients based on the relationship between local gradients and the aggregated gradient. The GMM effectively distinguishes toxic gradients in non-IID data by capturing the complex underlying distribution, often inadequately represented by a single Gaussian. GMM models the distribution as a mixture of multiple Gaussians, addressing non-IID intricacies.

The auditor employs the MD to identify legitimate gradients misclassified as malicious, effectively addressing non-IID issues. MD, a powerful similarity metric, incorporates a covariance structure crucial for complex distributions in encrypted gradients. Unlike cosine similarity, which fails to capture accurate similarity, MD excels in modeling complex and

multi-modal data. Existing strategies either support IID or struggle with such distributions. In contrast, the proposed internal auditing model accommodates heterogeneity and multi-modal data while ensuring privacy and computational efficiency, making it a superior choice. Moreover, the auditor employs AHE to encrypt user-side local gradients, ensuring the enactment of PP defence mechanisms server-side without disclosing user data. AHE, exemplified by the widely-studied Paillier cryptosystem, allows computation on ciphertexts while maintaining plaintext confidentiality [40]. The Paillier cryptosystem is illustrated by defining $r = ab$ with a and b as two prime factors of equal size. Let c represent a ciphertext in the set of integers ($c \in \mathbb{Z}$), and let $k_1, k_2 \in \mathbb{Z} \times r$ represent two keys. It is possible to compute $Enc(k_1 + k_2)$ using only the key and the encryption function $Enc(k_1)$, $Enc(k_2)$. Additionally, $Enc(c \times k_1)$ can be calculated given a constant c . For completeness, we briefly describe the Paillier cryptosystem process: **Key Generation:** Let us define i as the modulus, the product of two prime numbers, a and b . We define the Euler's totient function as $\psi(i) = (a - 1)(b - 1)$ and the Carmichael function as $\eta(i) = lcm(a - 1, b - 1)$. Confirm $gcd(i, \psi(i)) = 1$ or select another modulus. Pick a random integer $f \in \mathbb{Z}_{i^2}$, so that i divides the order of $f \in \mathbb{Z}_{i^2}$. This condition can be verified by using $\beta = [L(f^{\mu(i)} \text{ mod } i^2))]^{-1}$, where μ is the Carmichael function, and $L(x)$ is a function defined as $L(x) = (x - 1) \text{ div } i$. The Paillier public key is set to (i, f) , and the private key to $(\eta(i), \beta)$. If $f = r + 1$, then $\xi(i) = \eta(i)$, and $\beta = \mu(i)^{-1} \text{ mod } i$, which simplifies key generation. In the encryption phase, a message $k \in \mathbb{Z}_i$ is taken as input. A cryptographically secure random number generator within the cryptographic software or hardware produces a random value $n \in \mathbb{Z}_i^*$, which is the randomization factor. The Paillier encryption algorithm then creates the ciphertext, $E(k) = c = f^{n \cdot k} \text{ mod } i^2$, where m represents the message to be encrypted and f and r are elements of the public key. During decryption, the cryptographic software or hardware takes the ciphertext $c \in \mathbb{Z}_{i^2}^*$ as input. It uses the Paillier decryption algorithm to restore the original message. This is achieved by computing $Dec(c) = k = L(c^{\mu(i)} \text{ mod } i^2) \times \beta \text{ mod } i$, where β is part of the private key and L and μ_i are functions defined in the Paillier. The auditor enables effective identification and elimination of malicious users, enhancing computational efficiency in the AHE application. This targeted exclusion reduces overhead from processing harmful gradients, preserving model integrity and reducing computational complexity. Consequently, the FL system achieves higher throughput, prioritizes authentic updates, and improves accuracy and efficacy, resulting in an optimized and efficient system.

A. System Setup

In the system setup, four main steps are involved. The first step is **Registration**, where users interested in participating in FL register with the auditor. Then, the auditor creates and distributes keys, including public and private key shares, and assigns a tag ID to each registered user. This is the **Key Distribution** step. The auditor produces a pair of asymmetric keys (pk, qk) for users, utilizing the

Algorithm 1 System Setup**Require:** Number of users N

- 1: User registration, key and model distribution, and audit table creation.
- 2: **Step 1:** Register users and assign unique IDs
- 3: **for** user $n \in \{1, 2, \dots, N\}$ **do**
- 4: Register user n and assign a unique ID Tag_ID_n
- 5: **end for**
- 6: **Step 2:** Distribute keys
- 7: **for** user $n \in \{1, 2, \dots, N\}$ **do**
- 8: Generate a Paillier cryptosystem key pair (pk_n, sk_n)
- 9: **end for**
- 10: **Step 3:** Distribute the initial global model $M(0)$ to users
- 11: Encryption $E = (KeyGen, Enc, Dec)$ with AHE:
 - $Enc_{pk}(x_1) \cdot Enc_{pk}(x_2) = Enc_{pk}(x_1 + x_2)$
 - $Enc_{pk}(x_1)^t = Enc_{pk}(t \cdot x_1)$
- 12: **Step 4:** Generate the audit table
- 13: Initialize an empty *Update_Table*
- 14: **for** user $n \in \{1, 2, \dots, N\}$ **do**
- 15: Generate an *Encrypted_Table_n* for user n using their public key pk_n
- 16: ($Tag_ID_n, Encrypted_Table_n$) to the *Update_Table*
- 17: **end for**
- 18: Internal auditing and make the *Update_Table*

Paillier cryptosystem, where pk represents the public key and qk signifies the private key. Users use pk for sending gradient and qk for the global model. The encryption scheme, denoted as $E = (KeyGen, Enc, Dec)$, is employed. *KeyGen* generates the key pair in E , while *Enc* and *Dec* represent the encryption and decryption algorithms. An AHE scheme E satisfies the following properties: 1- $Enc_{pk}(x_1) \times Enc_{pk}(x_2) = Enc_{pk}(x_1 + x_2)$. 2- $Enc_{pk}(x_1)^t = Enc_{pk}(t \times x_1)$. For the **Model Distribution** step, the initial global model $M(0)$ is encrypted using the auditor's public key and then distributed to each registered user. Each user decrypts the model using their private key qk . The *Encrypted_Table_n* generated in step 4, **Audit Table Generation** step, contains encrypted representations of user-specific data, such as gradient updates or model parameters, encrypted using the user's public key pk_n . This table serves as a secure means to store and manage user data for auditing purposes, ensuring data confidentiality and integrity.

B. Internal Audit Protocol

The audit module includes three phases: Phase 1 generates keys and IDs, Phase 2 detects and filters poisoning gradients, and Phase 3 aggregates gradients, as discussed below. **Phase 1:** The audit module initializes the federated system. It generates pair-keys (public-private) $K = (pk; qk)$ for each users n , ($n \in N$, $|n| = N$), and assigns Tag_ID for user, $\{T_1, T_2, \dots, T_n\}$. Next, it generates the *Update_Table* that includes $(Tag_ID, Table_Tag)$ to handle internal auditing on the user side. **Phase 2:** After obtaining users' encrypted gradients, the auditor examines gradients at round t and

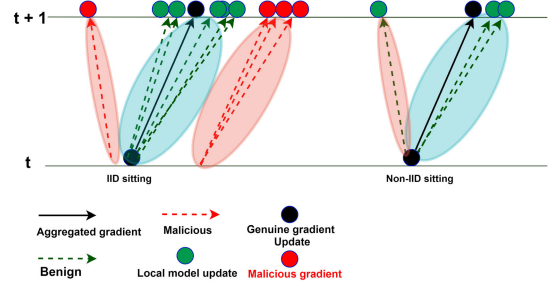


Fig. 3. Examples of malicious gradients.

categorizes them into malicious and benign clusters using GMM. To uncover poisoning adversaries' intricate behavior, the auditor uses MD to track gradients in round $t + 1$. In round t , a local gradient $gi(t)$ with substantial magnitude may potentially be a malicious gradient aimed at misdirecting the aggregated gradient. In our proposed PPFL model, the GMM is specifically adapted to handle the complexities of non-IID data distributions in federated learning environments. This adaptation is crucial given that in heterogeneous data scenarios, such as those depicted in Fig. 3, distinguishing between benign and malicious gradients can be particularly challenging. In a non-IID setting, for instance, it is possible for a benign user's local gradient to resemble the global model gradient closely, complicating the task of accurately identifying malicious activities. To enhance the precision of our approach, we integrate the MD in conjunction with GMM. This method is employed to refine the monitoring of user gradient trajectories within the identified normal and malicious clusters. Specifically, at round $t + 1$, the MD is calculated for each gradient, considering the mean and covariance matrix of the respective clusters. These parameters are determined using GMM following the separation of gradients into normal and malicious groups. The process begins with the calculation of the mean vector and covariance matrix for each cluster. By leveraging this metric, our model effectively reduces the likelihood of misclassifying benign gradients as malicious in non-IID scenarios. Let's consider the following steps:

1- Calculate the mean of each group: Compute the mean vector for the normal and malicious gradients separately. The mean vector is the average of all the gradients in each group. **2- Calculate the covariance matrix for each group:** Compute the covariance matrix for the normal and malicious gradients separately. The covariance matrix captures the variance and correlation structure within each group of gradients. **3- Calculate the MD for each gradient:** For each gradient, calculate the MD to the mean of the respective group (normal or malicious) using the $MD(x) = \sqrt{(x - \mu)^T \Sigma^{-1} (x - \mu)}$, where x is the gradient vector, μ is the mean vector of the respective group (normal or malicious), Σ is the covariance matrix of the respective group (normal or malicious), Σ^{-1} is the inverse of the covariance matrix, and T denotes the transpose operation. When computing MD, utilize the mean and covariance matrix of the corresponding group (either normal or malicious) to which the gradient belongs. MD measures the distance between a gradient and its group's mean, considering its covariance structure. Gradients

exhibiting smaller MD values are more likely to be authentic as they adhere closely to the group's mean and distribution. Large MD values indicate a significant distance between the gradient and its group's mean, suggesting the gradient be an outlier or misclassified as malicious. When the MD is large, the gradient x is far away from the center of its respective group and is an outlier. Large MD values indicate a significant distance between the gradient x and the mean of its corresponding group. Hence, it is more likely that gradient x is misclassified as an anomaly (Within normal and malicious gradients that visualize the users' direction and detailed description of GMM and MD). One big difference between adversary users who pretend to have non-IID data and normal users (with non-IID data) is that they randomly initialize the local model since attackers do not know any local training data. As a result, their gradient is near random guessing, and we detect and trace the gradient direction for the fake and genuine gradients. In this regard, we dynamically set the threshold, T , based on the distribution of the MD values for the normal gradients by using the standard deviation of the MD values. Let's denote the MD values for the normal gradients as $\mathbf{MD}_{\text{normal}} = MD_1, MD_2, \dots, MD_n$. The mean and standard deviation of the MD values for the normal gradients can be calculated as $\mu_{\text{normal}} = \frac{1}{n} \sum_{i=1}^n MD_i$ and $\sigma_{\text{normal}} = \sqrt{\frac{1}{n-1} \sum_{i=1}^n (MD_i - \mu_{\text{normal}})^2}$. The threshold can then be set as a multiple of the standard deviation of the MD values for the normal gradients: $T = k \cdot \sigma_{\text{normal}}$ where k is a constant that we choose based on our desired sensitivity level and system performance. Finally, employing an MD threshold, gradients are selectively weighted, prioritizing authentic ones for aggregation. This culminates in a Byzantine-resilient gradient aggregation procedure, updating the global model with filtered or weighted gradients.

1) *Phase 3:* When the *Update_Table* is ready for aggregation, the auditor passes them to the server. Indeed, the auditor-server interaction exists for Byzantine-tolerant gradient aggregation in the FL setup. Within a specific round, the auditor monitors the update tables and passes them to the server when they are ready for aggregation. The server then applies a Byzantine-tolerant aggregation function on the received update tables to produce aggregated updates. This process repeats for all updated tables available. Finally, the server updates the global model using the aggregated updates, ensuring a robust aggregation approach that is resilient to potential Byzantine attacks, ultimately contributing to the overall reliability and performance of the FL system.

VI. THEORETICAL ANALYSIS

A. Secure Training

Secure training consists of three phases: users' local training, auditor training, and the robust aggregation phases as follows: **a) Users' local training:** In this stage, we assume that the maximum proportion of malicious users within the subset does not exceed 50%. During round t , every user n_x^t , where x ranges from 1 to m , obtains the encrypted model $[M^t]_{pk}$, utilizing their respective public key pk . Once decrypted, n_x^t trains and acquires the local gradient vector g_x^t . Instead of

Algorithm 2 Training the Auditor

Require: Dataset $\mathcal{D}$ with normal and malicious (g_i, g_i^*)

- 1: Split $\mathcal{D}$ into training set $\mathcal{D}_{\text{train}}$ and validation set $\mathcal{D}_{\text{val}}$
- 2: Extract features X_{train} from $\mathcal{D}_{\text{train}}$ and normalize them
- 3: Initialize GMM parameters : μ , Σ , and mixing coefficients π
- 4: **repeat**
- 5: **E-step:** Compute $P(c_k|x_i)$ for each gradient x_i and cluster c_k
- 6: **M-step:** Update GMM parameters μ , Σ , and π using the computed posterior probabilities
- 7: **until** convergence or maximum iterations reached
- 8: Determine the optimal number of clusters k by incrementally increasing k from 1 while minimizing the BIC: $\text{BIC} = -2 \log L + k \log n$, where L is the maximized likelihood, and n is the number of gradients in $\mathcal{D}_{\text{train}}$
- 9: **for** each gradient x_i in $\mathcal{D}_{\text{val}}$ **do**
- 10: Calculate $MD(x_i) = \sqrt{(x_i - \mu_k)^T \Sigma_k^{-1} (x_i - \mu_k)}$
- 11: **end for**
- 12: Determine the threshold T for MD
- 13: Evaluate the auditor's performance
- 14: **if** performance is not satisfactory **then**
- 15: Fine-tune the auditor
- 16: **end if**

merely uploading the current gradients, we apply Stochastic Gradient Descent (SGD) with momentum to refine the update. This approach incorporates a sequence of previous gradients using an exponential decay factor ∂ ($0 < \partial < 1$), resulting in the submitted user parameters: $g_x \cong \sum_{l \in [0, t]} \partial^{t-l} g_x^l$. Similar to previous studies (i.e., [41]), establishing momentum's role in accelerating convergence, reducing variance, and enhancing model robustness mitigates poisoning attacks.

b) Auditor training: We present an auditor to detect and mitigate malicious gradients via GMM and MD, following a comprehensive training process. The procedure includes acquiring labeled data with both normal (g_i) and malicious gradients (g_i^*), extracting relevant features (X_i), and normalizing these for uniform scaling. The data ($\mathcal{D}$) is then split into training and validation sets ($\mathcal{D}_{\text{train}}$, $\mathcal{D}_{\text{val}}$). Our GMM, trained via Expectation-Maximization [42], estimates parameters for benign and malicious gradients, initially setting $k = 2$ clusters as per [6]. This setup aids in calculating the MD between validation set gradients and GMM means. Recognizing potential misclassifications in scenarios with exclusively benign clients under the $k = 2$ assumption, we introduce an iterative process. This method starts with one cluster, incrementally increasing the number and using the Bayesian Information Criterion (BIC) for performance assessment. This dynamic clustering effectively adapts to the actual encrypted gradient distribution, minimizing false classifications in homogeneous benign environments.

B. Optimization

ooo This section formally describes proposed optimization techniques to reduce communication and computation

overhead in the PPFL model. **Removing redundancy:** Let G be the collection of unique gradients sent by users, where $|G| \leq n$. The aggregation function can be rewritten only to include unique gradients and their corresponding frequencies as $M_{\text{new}} = M_{\text{old}} + \eta \sum_{g \in G} f(g) \cdot g$ where $f(g)$ is the frequency of gradient g in the set of received gradients. To manage redundancy removal, the algorithm first identifies duplicate gradients across the network. Each gradient is hashed, and a frequency map is created to track the occurrence of each unique gradient hash. This approach ensures that only distinct gradients contribute to the updated model, thereby enhancing computational efficiency. We reduce the computation cost by aggregating only unique gradients based on their frequencies.

Reducing the communication round: After applying the ‘Removing redundancy’ optimization, we denote r' as the new, reduced number of communication rounds. The reduction in communication rounds is facilitated by a synchronized schedule, allowing users to compute more local updates between interactions with the server. This strategy minimizes redundant data transmission while ensuring consistent model updates. We can have each user perform local updates between communication rounds to reduce the number of communication rounds. Based on the local updates before and after optimization, let

t be the ratio = $\frac{\text{local updates after optimization}}{\text{local updates before optimization}}$. The new number of communication rounds r' is given by $= \frac{r}{t}$. Increasing the number of local updates makes gradient exchanges less frequent, reducing communication overhead. **Reducing the computing cost:** A more efficient AHE scheme can reduce computing costs. AHE is used to encrypt, decrypt, or perform arithmetic operations on the model M using $C(M)$. AHE should meet the requirements: $C'(M) < C(M)$. Here, $C'(M)$ represents the computing cost of the new AHE scheme. In selecting a more efficient AHE scheme, computational complexity, and security trade-offs are carefully evaluated. The overall computational cost of the PPFL model is reduced by using a more efficient AHE scheme. These optimizations in the PPFL model ensure a more efficient and scalable solution for real-world applications by reducing communication and computation overhead. Algorithm 3 demonstrates optimization steps for the PPFL model, including removing redundancy, reducing the communication round, and reducing the computing cost.

C. Correctness

Correctness refers to ensuring the accuracy of encrypted gradient sharing and auditing when filtering malicious gradients.

Lemma 1: Upon receiving user updates via the audit table φ , the server employs these updates to refine the global model. The incremented version of the global model is derived from the equation: $\varphi_{\tau+1} = \frac{1}{N} \sum_{i=1}^N (1 - M^{ki}_t) \varphi_t + M^{ki}_t \varphi^{ki}_t$. Here, $\varphi_{\tau+1}$ represents the updated audit table at the subsequent time step, N stands for the total number of users, M^{ki}_t is the model from the i -th user, and φ^{ki}_t denotes the i -th user's entry in the audit table at time step τ .

Lemma 2: The Auditor holds the security property, such as pair keys (pk, qk) , and learns nothing about private data like gradients and the aggregation results.

Algorithm 3 Optimization of PPFL Model

```

1: Procedure: OPTIMIZEPPFL( $M_{\text{old}}, G, n, r, AHE, t$ )
2: Initialization:  $M_{\text{new}} \leftarrow M_{\text{old}}$ 
3: Optimization 1: Removing redundancy
4: for  $g \in G$  do
5:    $f(g) \leftarrow$  frequency of gradient  $g$ 
6:   // Hash each gradient  $g$  to identify duplicates
7:   // Create a set  $G_{\text{unique}}$  of unique gradients
8:   // Use only gradients in  $G_{\text{unique}}$  for the next step
9:    $M_{\text{new}} \leftarrow M_{\text{new}} + \eta f(g) \cdot g$  // For  $g \in G_{\text{unique}}$ 
10: end for
11: Optimization 2: Reducing the communication round
12:  $t \leftarrow$  ratio of local updates
13:  $r' \leftarrow \frac{r}{t}$ 
14: Optimization 3: Reducing the computing cost
15: Choose an efficient AHE such that  $C'(M) < C(M)$ 
16: return  $M_{\text{new}}, r', AHE$ 

```

Lemma 3: AHE ensures the confidentiality of both the user and server sides since user i encrypts its gradients donate by x_m^i . Then, each user sends $\text{Enc}(\sigma_m^i)$.

Lemma 4: The Paillier cryptosystem is clear by defining a random value as r , $r = ab$ to have two prime factors of equal size a and b and letting $c \in \mathbb{Z}$ and $k1, k2 \in \mathbb{Z} \times r$. It is possible to compute $\text{Enc}(k1 + k2)$ using only the public key and the Encryption $\text{Enc}(k1)$, $\text{Enc}(m2)$. Additionally, $\text{Enc}(m \times k1)$ can be calculated given a constant m . Under Lemma 1 and 2, the audit protocol enables the *Updated_Table* to carry user gradients for the aggregation process. The *Updated_Table* is populated by users ($U_i \subseteq U$) at round t , with gradients reflecting diverse data quality and distributions. Trustworthy auditors and user compliance to the workflow, absence of malicious activity, ensure correct gradient vector W aggregation.

Theorem 1: Robustness against malicious gradients via auditability - IID. *Proof:* Based on Lemma 1 and the participation of registered users as ($U_i \subseteq U$, $i \in N$), we have $\{U_1, U_2, \dots, U_n\}$, that $j \subseteq U_i \subseteq U$ denotes users that send malicious gradients. The assumption is $|j| \leq \lfloor n/2 \rfloor$, and the auditor traces users based on the audit protocol to find the adversarial users. Our proposed model checks gradient distribution and behavior for all users to remove the effect of adversary user participation and obtain robustness. Therefore, the auditor can confirm user k and calculate that gradient gk is valid. Adversarial users who send malicious updates will suspend their ID . We can guarantee to reduce their effect of them. In this regard, based on proof of Lemma 1, the symbol $\frac{U_i}{U_{i+1}}$ represents users who uploaded data in round t , but some users may still inject false data in round $t + 1$ in IID setting. Thus, each user holds a local gradient denoted as x_n (where $n \in U$). According to Lemma 2, the auditor is able to obtain the following expression: $[[\bar{W}]] pk = \prod i = 1^n [[\bar{W}_i]] pk = \sum i = 1^n [[\bar{W}_i]] pk$. Here, $\bar{W}$ represents the aggregated encrypted gradients, and $\bar{W}_i$ represents the encrypted gradient from the i -th user. The symbol $\prod_{i=1}^n$ denotes the product operator, indicating that the encrypted gradients from all users are multiplied together. Likewise,

$\sum_{i=1}^n$ represents the summation operator, indicating that the encrypted gradients from all users are summed together. It is important to note that the encrypted gradients have been received confidentially and can be expressed as $\bar{W} = \sum_{i=1}^n W_i$ (see **Lemma 3**). In the following round, the auditor computes the GMM for gradients, then tracks w_{t+1} with the MD, using the parameters provided by every user in round $t + 1$, $w_{t+1} \leftarrow \sum_{u \in U_t} w_t^u \frac{P_{uMk}}{M}$ to track benign and adversaries. The assumption is that there are fewer than half the users who are adversaries $\left[\frac{U_t}{2}\right]$; hence, the *mean* of each cluster is expected to correspond to the similarity value of at least one benign user. The auditor first calculates the covariance matrix for cluster the variance and correlation structure and then applies *MD* to detect injected false data (see Audit section V-B). Therefore, $\bar{w}_i, \bar{w}_j, \bar{w}_z, i, j, z \in F_M$ ($i, z \in [1, N], j \in [1, N/2]$) are gradients corresponding to the similarity position of benign users and adversaries. According Lemma 4, benign users gradients, $\bar{w}_i, \bar{w}_z \in F_M$ satisfies:

$$\bar{w}_i + \bar{w}_z \equiv x_t^i + y_t^z \pmod{m_t} \quad (3)$$

While gradients of adversarial users $\bar{w}_j \in F_M$ cannot satisfy Eq. 3. Note that $t = \{1, 2, \dots, k\}$, x_t^i , t is an element in the P_i 's original gradient W_i .

1) *Theorem 2: Robustness against malicious gradients via auditability - non-IID: Proof:* According to Theorem 1, there is a subset of user gradients donated by $(H_i \subseteq U, i \in [N/2])$ that lie on the boundary of gradient similarities, as indicated by Eq. 2. This implies that users $i \in D_i$ possess non-IID data. However, the auditor must distinguish between legitimate users and adversaries, introducing gradient drift. Thus, in the t -th round, the auditor leverages the gradient of the global model w_*^{t-1} from the previous round to analyze the current behavior of the gradient w^t , where $w_*^{t-1} = (w^t - w^{t-1})/\varepsilon$, and ε represents the direction of the global model gradient (**Lemma 4**). Consequently, the auditor approximates the benign gradient update in the t -th round as $\bar{w}_*^t \approx w_*^{t-1} = (w^t - w^{t-1})/\varepsilon$. In a gradient drift attack, the direction of the gradient ε does not converge, as the attacker can use an inappropriate scaling factor ε to amplify fake local model updates, ensuring their magnitudes are no smaller than those from genuine users. The attacker i sends a fake gradient as $w_*^i = -\varepsilon(w^t - w^{t-1})$.

D. Privacy Preservation

The proposed model utilizes the Paillier cryptosystem that provides additive homomorphic properties [40]. In our model, privacy preservation refers to safeguarding the confidentiality and integrity of data during the FL process. This encompasses user privacy, server privacy, and gradient privacy.

Lemma 5: For any message $k \in Z_i$, the Paillier encryption and decryption functions preserve the original message: $Dec(Enc(k)) = k$.

Proof: Given the Paillier encryption and decryption functions, we need to show that $Dec(Enc(k)) = k$. Encrypting message as k : $Enc(k) = c = f^k r^i \pmod{i^2}$, where r is a random value in Z_i^* and f^k is public-key encryption [43]. Decrypting the ciphertext as c : $Dec(c) = k' = L(c^{\eta(i)} \pmod{i^2}) \cdot \beta \pmod{i}$ that β is inversion factor of

cryptosystem. Substituting $Enc(k)$ with the decryption function: $k' = L((f^k r^i)^{\eta(i)} \pmod{i^2}) \cdot \beta \pmod{i}$. Using the property that $f^{i\eta(i)} \equiv 1 \pmod{i^2}$ and assuming that $r^i \equiv 1 \pmod{i^2}$ for any $r \in Z_i^*$, we can simplify the above expression as: $k' = L(f^{k\eta(i)} \pmod{i^2}) \cdot \beta \pmod{i}$. Now, by applying the L function and defining β : $k' = L(f^{k\eta(i)} \pmod{i^2}) \cdot [L(f^{\eta(i)} \pmod{i^2})]^{-1} \pmod{i}$ (recall that $L(\beta) = (\beta - 1) \div i$) we will have $k' = \frac{f^{k\eta(i)} - 1}{i} \cdot \frac{i}{f^{\eta(i)} - 1} \pmod{i}$ [43]. After canceling the terms, we are left with $k' = k \pmod{i}$. Thus, the Paillier cryptosystem is complete, as $Dec(Enc(k)) = k$. If we consider N users, we have a set as $U = \{U_1, U_2, U_3, \dots, U_n\}$, so each user U_i can generate data x_i . Based on **Lemma 5**, to maintain privacy, users U_i cannot reveal x_i to others. Servers should not be aware of $x_i \quad \forall i \in \{1, n\}$.

Consider a set of N users $U = U_1, U_2, U_3, \dots, U_n$, each generating data x_i . We utilize AHE to protect privacy and ensure that $c_i = Enc(x_i)$, preserving both user and server privacy. **User Privacy:** Our system enhances FL's inherent user privacy measures. It guarantees that users cannot access each other's data, a critical aspect of FL. For instance, if U_i generates data x_i and U_j generates data x_j , they will only deal with the encrypted data $c_i = Enc(x_i)$ and $c_j = Enc(x_j)$, respectively. This approach ensures that U_i remains ignorant of the data and activities of U_j , and vice versa. **Server Privacy:** In our model, server privacy refers to the measures implemented to prevent the server S from accessing or understanding the actual content of the data it processes. Despite being a central entity in coordinating the FL process, the server S is treated as untrusted. It only manages encrypted data, ensuring that user data remains confidential and the server cannot infer any sensitive information from the data it receives. **Gradient Privacy:** In our model, gradient privacy is achieved through the encryption of gradients by users before they are uploaded to the server. This method ensures that the aggregation server cannot access the plaintext of gradients, thereby safeguarding the privacy of the model's training process. By employing the secure Paillier cryptosystem, our system effectively prevents unauthorized access to gradient information.

VII. EXPERIMENTAL ANALYSIS

Our evaluation is conducted on an Intel i7-10700KF CPU, 16 GB DDR4 memory, RTX 2070 GPU system, operating on Ubuntu 20.04 with PyTorch and Python 3.9. We configured cryptographic primitives in the federated system using the Paillier library [44]. Due to maintaining parity with the compared academic literature such as [3], [5], [6], [7], [10], and [33], the logistic regression classifier model and three classification datasets: MNIST, KDDCup, and Amazon, under both IID and non-IID settings, is considered for evaluation and to ensure a fair comparison. In our experimental setup, specifically focusing on non-IID data, we adopt the label skew approach, where each user stores data samples from a single class. This method is in alignment with the methodologies utilized in seminal studies [45], [46], and as observed in the ShieldFL [6]. Our decision to adopt this approach facilitates a more controlled evaluation environment and allows for

an accurate benchmarking of our model against established methods under similar non-IID conditions. In IID, data is uniformly partitioned among users. Training parameters are customized per dataset. For MNIST and KDDCup, we use 300 iterations and a batch size of 50. For Amazon, we use 60 iterations and a batch size of 10 due to a higher feature count and fewer class samples. The learning rate l is 0.01 for MNIST and KDDCup and 0.005 for Amazon. Parameters are optimized through cross-validation on the training set. To evaluate the performance of our approach, we simulate a range of model poisoning attacks leveraging encrypted local gradients. These simulations examine varying degrees of adversarial presence, represented by different attack ratios, α , which we set at 10%, 20%, 30%, and 50%. In evaluating FL, similar to the assessment of related works based on [6], the number of users is related to the number of classes in each dataset to provide IID and non-IID settings. Therefore, in the context of the MNIST dataset, we conduct our evaluation with 10 users, and the targeted attack is from Class 1 to Class 7. For the KDDCup dataset, 23 users participated, and the attack aims to transform instances from Class 9 to Class 11. For the Amazon dataset, our evaluation involves 50 users and targets attacks from Class 1 to Class 7. In addition to the above configurations, we establish a baseline model representing a poisoned PPFL system without any defence mechanisms or internal auditing. This baseline model serves as a comparison point, illustrating the enhanced effectiveness of our proposed approach in defending against various model poisoning attacks.

A. Accuracy, Robustness, & Malicious Alarm Analysis

In model poisoning, adversaries aim to optimize $\arg\max_{i \in [1, n]} H^t(w - w^*)$, where H is a vector representing the model's direction changes, W is a pre-attack model, and W^* is a poisoned model in targeted and untargeted attacks.

Our evaluation metrics for targeted attacks encompass **Target Accuracy** (T_acc), reflecting the testing performance on target labels, and **Other Label Accuracy** (O_acc), assessing the learning performance on non-source and non-target labels. These metrics help identify potential auditing failures and unintended harm to the FL system. Additionally, **Overall Accuracy** (ACC) signifies the average learning accuracy across all labels, providing insights into the defence methods' efficiency against poisoning attacks. The **Malicious Alarm** (MA), evaluated through the Receiver Operating Characteristic (ROC) curve, gauges the defence algorithms' effectiveness in identifying malicious activities within the FL system. The ACC might differ from the target's and other labels' combined accuracy due to varying attack and defence strategies. For untargeted attacks, we retain the ACC and MA metrics. **a) $ACC_{non-IID}$:** Table I presents the accuracy of the proposed model and the baseline in non-IID settings for both targeted and untargeted attacks (with attack rate = %50). For the MNIST dataset, the baseline model yields a T_acc of 0.078, O_acc of 0.89, and ACC of 0.81 under targeted attack. The proposed model significantly improves performance, achieving 0.784 T_acc , 0.987 O_acc , and 0.979 ACC . Similarly, the proposed model attains 0.965 T_acc and 0.963 ACC for

TABLE I
EVOLUTION OF ACCURACY IN NON-IID SETTINGS

Datasets	Baseline				Proposed Model			
	Targeted Attack		Untargeted Attack		Targeted Attack		Untargeted Attack	
	T_acc	O_acc	ACC		T_acc	O_acc	ACC	
MNIST	0.078	0.89	0.81	0.784	0.987	0.979	0.965	0.963
KDDCup	0.015	0.94	0.782	0.761	0.995	0.992	0.989	0.967
Amazon	0.015	0.93	0.771	0.743	0.994	0.997	0.998	0.996

TABLE II
EVOLUTION OF ACCURACY IN IID SETTING

Datasets	Baseline				Proposed Model			
	Targeted Attack		Untargeted Attack		Targeted Attack		Untargeted Attack	
	T_acc	O_acc	ACC		T_acc	O_acc	ACC	
MNIST	0.09	0.2	0.15	0.11	0.989	0.995	0.97	0.968
KDDCup	0.049	0.6	0.58	0.52	0.997	0.995	0.992	0.991
Amazon	0.06	0.51	0.4	0.235	0.995	0.989	0.921	0.941

untargeted attacks, outperforming the baseline. The KDDCup dataset demonstrates similar improvements. The baseline model has 0.015 T_acc , 0.94 O_acc , and 0.782 ACC for targeted attacks, while the proposed model achieves 0.761 T_acc , 0.995 O_acc , and 0.992 ACC . The proposed model reaches 0.989 T_acc and 0.967 ACC for untargeted attacks. Lastly, the Amazon dataset's baseline model shows 0.015 T_acc , 0.93 O_acc , and 0.771 ACC under targeted attack. The proposed model significantly improves the performance with 0.743 T_acc , 0.994 O_acc , and 0.997 ACC . The proposed model achieves 0.998 T_acc and 0.996 ACC for untargeted attacks. These results demonstrate that the proposed model substantially outperforms the baseline model regarding accuracy across all three datasets under targeted and untargeted attacks in non-IID settings. **b) ACC_{IID} :** The accuracy of the proposed model is also evaluated in IID settings, where the training data are evenly distributed across all users. The results are presented in Table II, which covers both targeted and untargeted attacks (with attack rate = %50). In the case of targeted attacks, the proposed model demonstrates improved accuracy compared to the baseline model, highlighting its effectiveness in protecting against such attacks. For untargeted attacks, the proposed model also outperforms the baseline in terms of accuracy, emphasizing its robustness and resilience against different adversarial attempts. These results indicate that the proposed model performs consistently well in both IID and non-IID settings, demonstrating its ability to protect the FL system from various poisoning attacks while maintaining high performance levels. **c) $R_{TA_{non-IID}}$:** The robustness of the proposed model against targeted attacks is assessed by analyzing the accuracy trajectories for varying numbers of users ($|U| \in [10, 23, 50]$) and attack rates from 10% to 50%, as presented in Fig. 4. The results indicate that the proposed model demonstrates remarkable stability in terms of accuracy across different attack rates. This stability highlights the resilience of the proposed model against targeted attacks, maintaining high performance even as the proportion of malicious users increases. In summary, the proposed model exhibits a strong defence against targeted attacks, ensuring reliable and accurate outcomes across various attack scenarios. **d) $R_{UTA_{non-IID}}$:** Similarly, the performance of the proposed model against untargeted attacks with non-IID data is evaluated. As shown in Fig. 5, the model demonstrates remarkable resilience under varying conditions of untargeted

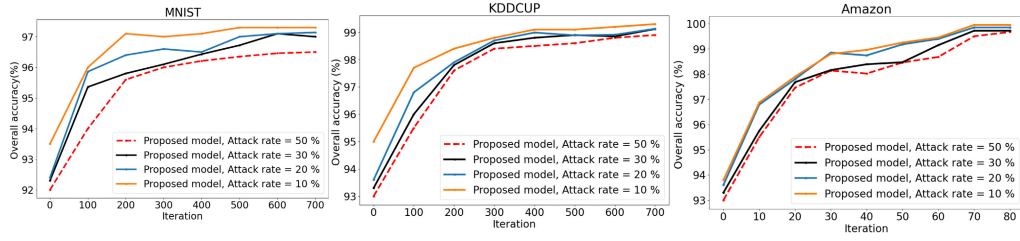


Fig. 4. Performance with targeted attack and non-IID data.

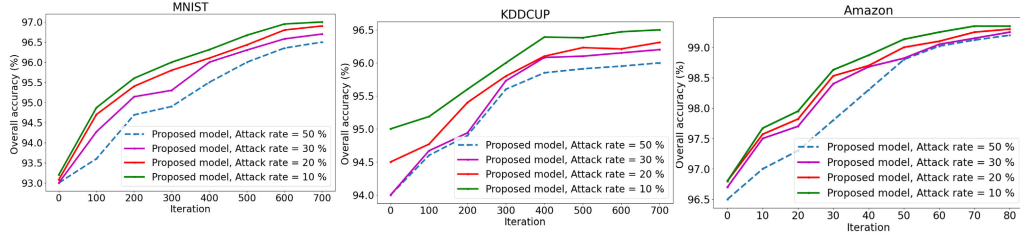


Fig. 5. Performance with untargeted attack and non-IID.

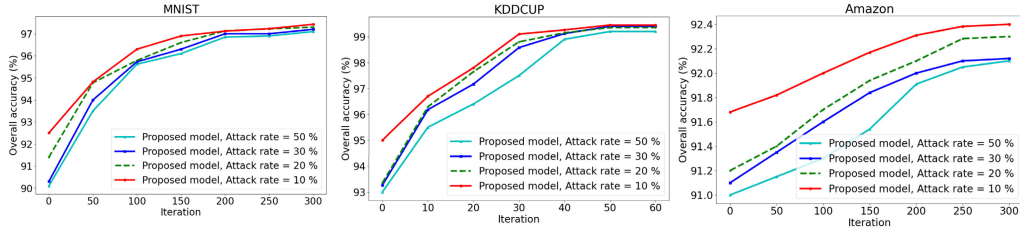


Fig. 6. Performance with targeted attack and IID data.

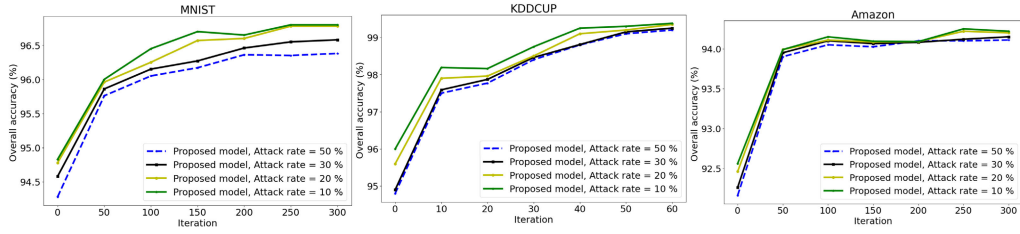


Fig. 7. Performance with targeted attack and IID.

attacks, ensuring accurate and reliable results even when facing adversarial attempts to disrupt the system. These findings further emphasize the robustness and effectiveness of the proposed model in defending against untargeted attacks and maintaining high-performance levels, even in non-IID data settings. **e)** $R_{TA_{IID}}$: The robustness of the proposed model against targeted attacks is also assessed using various attack rates in an IID data setting. Fig. 6 demonstrates the model's performance under these conditions. The proposed model maintains stable accuracy levels despite the varying attack rates, showcasing its robustness and resilience against targeted attacks in an IID data setting. This further highlights the model's effectiveness in ensuring the security and privacy of the FL system, even when facing a diverse range of adversarial attempts. **f)** $R_{UTA_{IID}}$: The performance of the proposed model is also evaluated against untargeted attacks in an IID data setting, where training data are evenly distributed across all users, as presented in Fig. 7. This scenario is crucial for understanding the model's resilience under more homogeneous data distribution conditions. The results show

that the proposed model exhibits high robustness against untargeted attacks in the IID data. Despite facing various types of adversarial attempts, the model maintains its accuracy levels, demonstrating its effectiveness in preserving the privacy and security of the FL system under these conditions. In summary, the proposed model has proven its efficiency and adaptability against attacks across different data settings, both IID and non-IID, including targeted and untargeted attacks. **g) MA evaluation:** We examine factors contributing to the differences in experimental results in our proposed model in the context of FL attacks. In particular, we investigate false alarms in the internal auditing protocol, which may include both false malicious and false clean determinations. To this end, we employ ROC analysis, a cutting-edge statistical model evaluation tool. The internal auditing of our proposed model demonstrates the superior ROC curve on MNIST, KDDCup, and Amazon datasets for both IID and non-IID settings. Moreover, the findings indicate that our model achieves the highest overall average ROC curve area across all three datasets (Fig. 8 and Fig. 9). We posit that the impressive ROC results

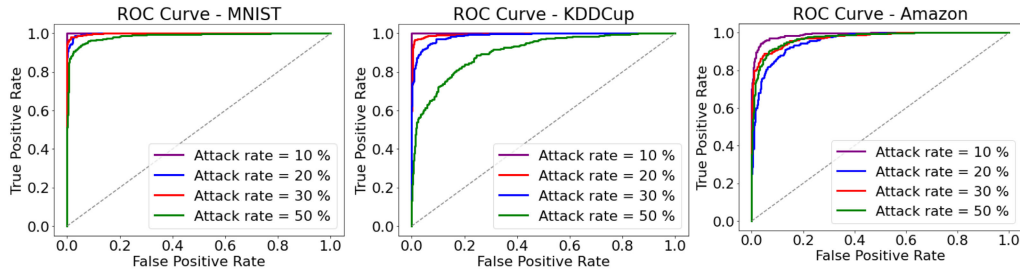


Fig. 8. Analyzing malicious alarms on IID data.

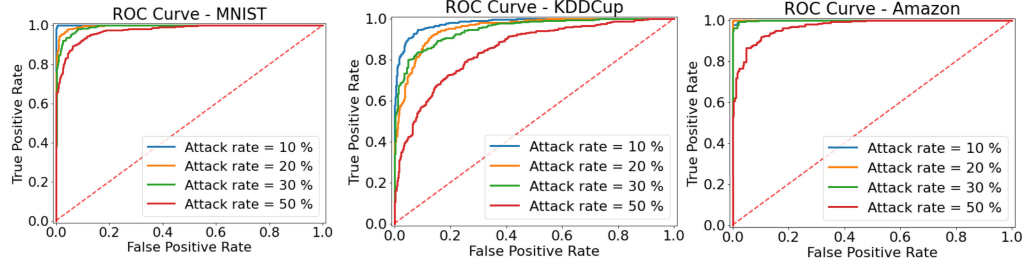


Fig. 9. Analyzing malicious alarms on non-IID data.

TABLE III
ACCURACY COMPARISON BETWEEN EXISTING SCHEMES

Work	Attack		Setting
	Targeted	Untargeted	
Trimmed-means	52.7	53.4	non-IID
	82.3	85.7	IID
Krum	71.4	78.3	non-IID
	90.7	90.4	IID
Auror	32.5	49.9	non-IID
	89.2	87.8	IID
PEFL	46.4	57.4	non-IID
	88.2	81.7	IID
Sybils	89.7	89.5	non-IID
	74.5	70.8	IID
FL-trust	37.8	43.4	non-IID
	75.1	69.7	IID
ShieldFL	90.1	89.4	non-IID
	90.3	90.2	IID
Propose model	96.5	96.3	non-IID
	97	96.8	IID

are closely related to the model's accuracy. The corresponding figures for IID and non-IID data further support the robustness of our model, solidifying its effectiveness in handling FL attacks.

h) Discussion: To demonstrate the effectiveness of our model, we compare its accuracy with several existing schemes, including Trimmed-means [7], Krum [10], Auror [33], PEFL [3], Sybils [5], FL-trust, and ShieldFL [6]. The comparison is using the MNIST dataset, with an attack rate of 50% and 500 training iterations. Both IID and non-IID data settings are considered. As shown in Table III, our model outperforms the existing schemes in both targeted and untargeted attacks under both IID and non-IID data settings. In particular, it achieves significantly higher accuracy in the non-IID setting for both targeted (96.5%) and untargeted attacks (96.3%). Similarly, our model exhibits outstanding performance in the IID setting with 97% accuracy for targeted attacks and 96.8% for untargeted attacks. The trimmed-means method, which relies on the attack rate, exhibits suboptimal performance when the accuracy falls below 60% and the attack rate is set to 50%. Schemes such as Krum, Auror, and PEFL face difficulties distinguishing local benign gradients trained on non-IID data, primarily due to the inherent challenge of differentiating between poisonous and benign gradients in the presence of divergence. In contrast,

ShieldFL achieves better accuracy in non-IID and IID settings, closely rivaling the top-performing Krum. On the other hand, Sybil's accuracy significantly drops in the IID setting. This is attributable to Sybil's treating the two most similar gradients as outliers, a tactic effective in countering model poisoning attacks in non-IID where poisonous gradients possess the same attack objective. However, this defence strategy in Sybils tends to cause misidentification within the IID setting due to the similarity among benign gradients trained with IID data. FL-trust performs poorly for both IID and non-IID settings, as it collects validation data through random sampling from local datasets. These results demonstrate that the proposed model not only outperforms another well-established scheme in terms of performance and accuracy but also provides an effective defence against various attacks. Further contributions of the proposed model, particularly in terms of enhanced privacy and reduced computational and communication overhead compared to previous studies, are presented in Section VII-B. The detailed discussion in this section underscores the unique advantages of our model in the context of FL.

B. Complexity & Computational Analysis

This section discusses the auditor's overhead and its impact on the overall system. We analyze the computation and communication costs of the auditor concerning the number of users, N , and the model dimension denoted by d . Key to our analysis is how the optimization techniques detailed in Section VI-B, particularly redundancy removal, contribute to the PPFL model's efficiency. By eliminating duplicate gradient computations and transmissions, we significantly reduce both computational load and communication traffic. This reduction is particularly impactful when considering the scalability of the system for a large number of users. We then present results to demonstrate the optimization (Section VI-B), efficiency, and effectiveness of our proposed model in mitigating model-poisoning attacks. Also, we critically compare different PP techniques and broaden our comparative analysis to include

TABLE IV
COMPUTATION SUMMARY OF THE PROPOSED MODEL

FL parts	without removing any users	Computation After removing attacks	Improvement cost
User	$\mathcal{O}(d_1 N \log_2 N)$	$\mathcal{O}(d_1 (N - A) \log_2 \frac{(N - A)}{2})$	$A \log_2 \frac{N}{(N - A)}$
Auditor	$(N K D + N d_1 \log d_1)$	$(N - A) K D + (N - A) d_1 \log d_1$	$\frac{A}{N} (K D + d_1 \log d_1)$
Server	$\mathcal{O}(d N \log N)$	$\frac{A}{N} \log \frac{(N - A)}{N}$	$\frac{A}{N} \log \frac{(N - A)}{N}$

TABLE V
COMMUNICATION SUMMARY OF THE PROPOSED MODEL

FL parts	without removing any users	Communication After removing attacks	Decrease in cost
User	$\mathcal{O}(d N + N^2)$	$\mathcal{O}(d(N - A) + (N - A)^2)$	$\frac{A}{N} \left[\frac{(N + A)}{N} \right]$
Auditor	$\mathcal{O}(L(Z + N))$	$\mathcal{O}(L(Z + (N - A)))$	$\frac{A}{N} \left[1 - \frac{Z}{N} \right]$
Server	$\mathcal{O}(W + N U)$	$\mathcal{O}(W + (N - A) U)$	$\frac{A}{N} \left[\frac{(N - U)}{U} \right]$

TABLE VI
OPERATION TIMES BASED ON VARIOUS KEY SIZES

Key Size (bit)	Operation time (# operations per second)		
	Encrypt	Decrypt	Generating keypair
128	0.000114 s (8771 ops/s)	0.000072 s (13919 ops/s)	0.001 S
256	0.000399 s (2508 ops/s)	0.000171 s (5847 ops/s)	0.03 S
512	0.002450 s (408 ops/s)	0.000783 s (1277 ops/s)	0.03 S
1024	0.013911 s (71 ops/s)	0.004607 s (217 ops/s)	0.2 S
2048	0.098179 s (10 ops/s)	0.028408 s (35 ops/s)	0.43 S

other encryption methodologies. **a) Complexity Analysis for Users:** The computation cost for user i includes data encryption dependent on the data size, d_1 . Hence, the computation cost of N users with d_1 data dimension is $\mathcal{O}(d_1 N \log_2 N)$. Communication costs involve sending user updates to the server and registering users in the Auditor during federated setup, totaling $\mathcal{O}(d N + 2 N)$. **b) Complexity Analysis for Auditor:** The auditor's computational complexity is tied to the auditing process involving GMM and MD, resulting in $(N K D + N d_1 \log d_1)$. Here, K signifies the count of Gaussian components, and D denotes data dimensionality. Communication complexity for the auditor is $\mathcal{O}(L(Z + N))$, where $Z \leq M$, L represents training iterations, Z is the count of gradient audits, and M is the number of reliability checks. **c) Complexity Analysis for Server:** The Server's complexity in the aggregation task is $\mathcal{O}(d N \log N)$, and communication with the Auditor and users in the FL setup is $\mathcal{O}(W + N U)$, where W and U are the counts of iterations with auditors and users, respectively. The efficiency gains from our optimization algorithm are reflected in the reduced computational and communication demands on the server, especially after removing attacks. Removal of the model-poisoning adversary reduces computation and communication costs. As demonstrated in Tables IV and V, we summarize the complexity analysis based on attack rate and show cost improvement via attack removal. While introducing additional overhead, the auditor is critical in enhancing system security by mitigating model-poisoning attacks. The Auditor's overhead is less significant with a low attack rate, making it cost-effective to incorporate this component for enhanced security. This balance between security and overhead underscores the importance of the auditor in maintaining a secure and reliable system.

d) Computational Time and Resources: Recognizing the limitations of smaller key sizes in the Paillier cryptosystem, which traditionally relies on RSA moduli, it is important to note that key sizes like 128 bits, once deemed secure, are now insufficient for robust security in the current

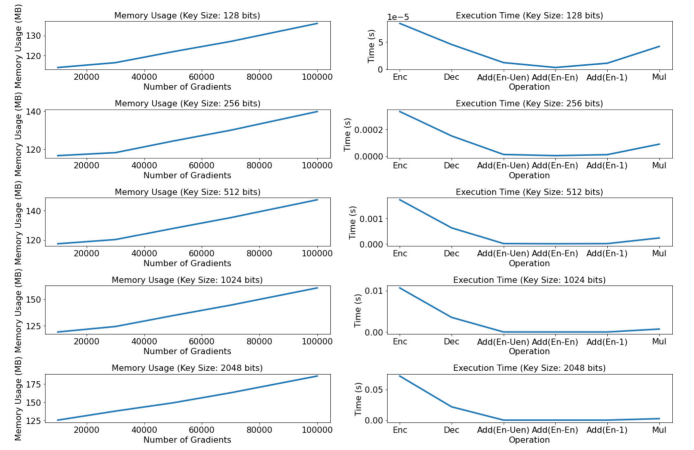


Fig. 10. Memory usage based on AHE.

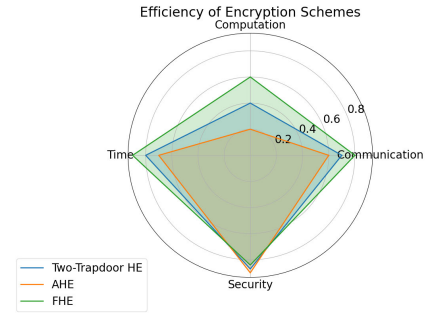


Fig. 11. Efficiency of Encryption Schemes.

technological landscape. Larger key sizes, in contrast, offer higher security against sophisticated cryptographic attacks. The key sizes presented in Table VI exemplify the trade-off between key size and computational efficiency. Adhering to current cryptographic standards with larger key sizes is strongly recommended for practical implementations in sensitive applications. The computational overhead for encryption and decryption in the AHE of our proposed model is quantified by monitoring operational times and calculating the average time per operation. Table VI details this overhead across various key sizes, utilizing the Paillier cryptosystem to measure time for encryption, decryption, and keypair generation. Additionally, we have carefully analyzed the impact of these key sizes on the operation times, clearly demonstrating how larger keys, while offering enhanced security, also bring increased computational demands. This analysis underscores the critical balance between security and efficiency in PPFL systems. In PP applications such as FL, strong encryption is vital. However, key size selection is application-dependent and should balance security and performance. Larger key sizes provide greater security but may impact overall performance due to increased computational overhead. We can choose appropriate key sizes for specific PP applications by evaluating the computational overhead. Fig. 10 displays the memory usage associated with different key sizes and numbers of gradients, as well as the execution times for various operations. This visualization underscores the relationship between key size and computational resources in Paillier encryption-based PP schemes. Larger key sizes, while bolstering security, increase computational overhead. Conversely, processing more

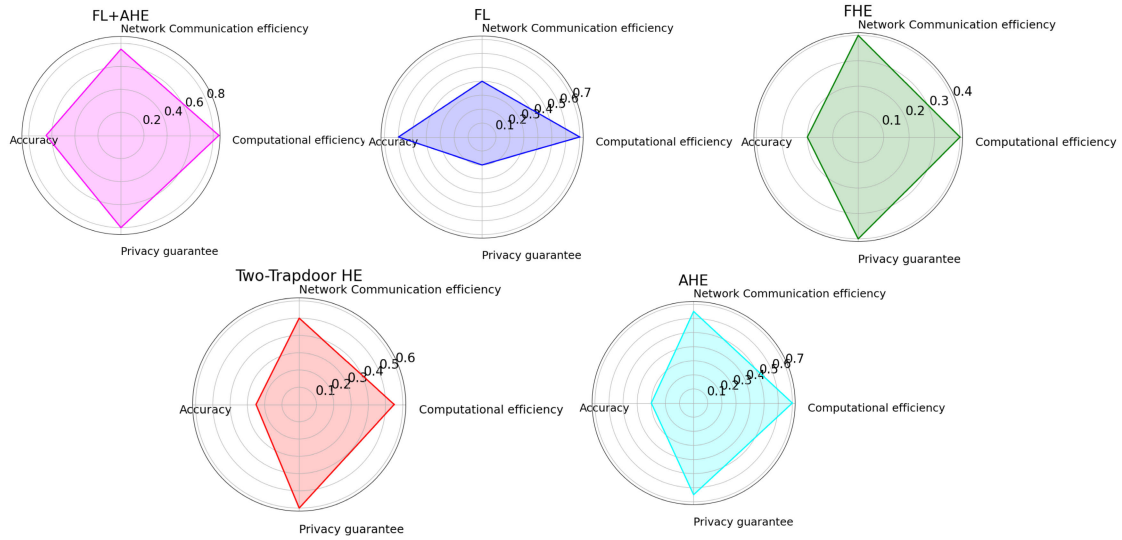


Fig. 12. Radar plots for FL, AHE, FHE, THE.

gradients elevates the computational load. Thus, our revised model carefully balances key size and gradient count to optimize security, accuracy, and computational efficiency, a balance crucial for the model's accuracy in FL environments.

e) Discussion: AHE is an encryption scheme that allows efficient homomorphic operations on encrypted data. Compared to FHE, which enables arbitrary computations, AHE is more efficient. FHE requires complex mathematical operations, consuming substantial computational resources. THE, a variant of FHE, offers superior privacy and lower computation and communication costs than FHE but higher than AHE. Its encryption and decryption time is also less than FHE. We introduce an efficiency score to evaluate the efficiency of AHE, FHE, and THE. This score is calculated in our model based on communication cost, computation cost, time, and security, with weights assigned to each metric. Fig. 11 provides radar plots comparing all encryption methods. A compact polygon closer to the grid center implies superior performance across all metrics. In contrast, a spread-out polygon or one near the grid's edge signifies poor performance in one or more metrics. As depicted in Fig. 11, AHE achieves a better overall computation, communication, and time score than other encryption schemes. This demonstrates that AHE is efficient while offering viable security within the context of the proposed model. Therefore, the proposed model is more efficient than other FHE or THE models, like ShieldFL [6]. Finally, we evaluated PP techniques (AHE, FHE, THE, FL) in our model, using performance and privacy criteria like computational efficiency, accuracy, and privacy. The aim was to illustrate our model's superiority over FL-based works such as Trimmed-means [7], Krum [10], Auror [33], PEFL [3], Sybils [5], FL-trust, and ShieldFL [6]. In this regard, we apply a generic ranking system ranging from the lowest score (0.1) to the highest score (1) for all comparison criteria, except for privacy, which is treated as a binary criterion. As shown in Fig. 12, the hybrid of FL + AHE (proposed model) demonstrates superior efficiency in terms of accuracy, computational, and communication costs compared to

homomorphic encryption models while maintaining privacy. On the other hand, FL (FL-based works) is the least efficient approach in terms of communication, as it requires exchanging numerous parameters between clients and the server.

VIII. CONCLUSION AND FUTURE WORK

We introduced an auditable PPFL model that effectively tackles poisoning, non-IID data, and computational and communication overhead issues in PPFL systems. Our model incorporates an auditor using a GMM and MD to identify benign and malicious encrypted gradients, ensuring robustness. We used AHE, which provides confidentiality and reduces overhead. Our model outperforms existing strategies and encryption techniques regarding accuracy, privacy, and cost, such as FHE and THE. We assessed our model using real-world datasets, focusing on two common model poisoning attacks, proving its capability to identify harmful gradients accurately and efficiently. This model offers a secure and effective FL solution in various real-world contexts. The broader impact of our model extends to sectors like healthcare and finance, where data privacy is paramount, paving the way for more secure data sharing and collaboration. Moreover, by facilitating secure and efficient FL, our model holds the potential for advancing artificial intelligence-driven solutions in smart city infrastructure and Internet of Things networks, where vast amounts of sensitive data require careful handling to unlock their full value while safeguarding privacy. In future developments, we aim to fortify our PPFL systems against the emerging threats posed by quantum computing. This will involve researching and implementing quantum-resistant cryptographic methods. Additionally, the integration of blockchain technology is envisaged to enhance the model's transparency and security, particularly in mitigating user-user collusion and sophisticated adaptive attacks. These advancements will not only address current limitations but also adapt our model to the rapidly evolving landscape of cybersecurity threats in federated learning.

REFERENCES

- [1] Y. Jiang, W. Zhang, and Y. Chen, "Data quality detection mechanism against label flipping attacks in federated learning," *IEEE Trans. Inf. Forensics Security*, vol. 18, pp. 1625–1637, 2023.
- [2] G. Xu, H. Li, S. Liu, K. Yang, and X. Lin, "VerifyNet: Secure and verifiable federated learning," *IEEE Trans. Inf. Forensics Security*, vol. 15, pp. 911–926, 2019.
- [3] X. Liu, H. Li, G. Xu, Z. Chen, X. Huang, and R. Lu, "Privacy-enhanced federated learning against poisoning adversaries," *IEEE Trans. Inf. Forensics Security*, vol. 16, pp. 4574–4588, 2021.
- [4] A. N. Bhagoji, S. Chakraborty, P. P. Mittal, and S. Calp, "Analyzing federated learning through an adversarial lens," in *Proc. 36th Int. Conf. Mach. Learn.*, May 2019, pp. 634–643.
- [5] C. Fung, C. J. Yoon, and I. Beschastnikh, "The limitations of federated learning in Sybil settings," in *Proc. 23rd Int. Symp. Res. Attacks, Intrusions Defenses*, 2020, pp. 301–316.
- [6] Z. Ma, J. Ma, Y. Miao, Y. Li, and R. H. Deng, "ShieldFL: Mitigating model poisoning attacks in privacy-preserving federated learning," *IEEE Trans. Inf. Forensics Security*, vol. 17, pp. 1639–1654, 2022.
- [7] M. Fang, X. Cao, J. Jia, and N. Z. Gong, "Local model poisoning attacks to Byzantine-robust federated learning," in *Proc. 29th USENIX Conf. Secur. Symp.*, 2020, pp. 1623–1640.
- [8] Y. Chang, K. Zhang, J. Gong, and H. Qian, "Privacy-preserving federated learning via functional encryption, revisited," *IEEE Trans. Inf. Forensics Security*, vol. 18, pp. 1855–1869, 2023.
- [9] H. Mozaffari, V. Sheikhal, and A. Houmansadr, "Every vote counts: Ranking-based training of federated learning to resist poisoning attacks," in *Proc. 32nd USENIX Secur. Symp. (USENIX Secur.)*, 2023, pp. 1721–1738.
- [10] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, "Machine learning with adversaries: Byzantine tolerant gradient descent," in *Proc. Adv. Neural Inf. Process. Syst.*, vol. 30, 2017, pp. 118–128.
- [11] G. Xu et al., "Hercules: Boosting the performance of privacy-preserving federated learning," *IEEE Trans. Depend. Secure Comput.*, vol. 20, no. 5, pp. 4418–4433, Sep./Oct. 2023, doi: [10.1109/TDSC.2023.3218793](https://doi.org/10.1109/TDSC.2023.3218793).
- [12] L. Zhao, Q. Wang, Q. Zou, Y. Zhang, and Y. Chen, "Privacy-preserving collaborative deep learning with unreliable participants," *IEEE Trans. Inf. Forensics Security*, vol. 15, pp. 1486–1500, 2019.
- [13] A. G. Sébert, R. Sirdey, O. Stan, and C. Gouy-Pailler, "Protecting data from all parties: Combining FHE and DP in federated learning," 2022, *arXiv:2205.04330*.
- [14] G. Xu, G. Li, S. Guo, T. Zhang, and H. Li, "Privacy-preserving decentralized deep learning with multiparty homomorphic encryption," 2022, *arXiv:2207.04604*.
- [15] S. Sav, A. Diaa, A. Pyrgelis, J.-P. Bossuat, and J.-P. Hubaux, "Privacy-preserving federated recurrent neural networks," 2022, *arXiv:2207.13947*.
- [16] S. Sav et al., "POSEIDON: Privacy-preserving federated neural network learning," 2020, *arXiv:2009.00349*.
- [17] A. Yazdinejad, A. Dehghantanha, G. Srivastava, H. Karimipour, and R. M. Parizi, "Hybrid privacy preserving federated learning against irregular users in next-generation Internet of Things," *J. Syst. Archit.*, vol. 148, Mar. 2024, Art. no. 103088.
- [18] X. Zhang, F. Li, Z. Zhang, Q. Li, C. Wang, and J. Wu, "Enabling execution assurance of federated learning at untrusted participants," in *Proc. IEEE INFOCOM Conf. Comput. Commun.*, Nov. 2020, pp. 1877–1886.
- [19] T. Gehlhar, F. Marx, T. Schneider, A. Suresh, T. Wehrle, and H. Yalame, "SafeFL: MPC-friendly framework for private and robust federated learning," in *Proc. IEEE Secur. Privacy Workshops (SPW)*, San Francisco, CA, USA, Jul. 2023, pp. 69–76, doi: [10.1109/SPW59333.2023.00012](https://doi.org/10.1109/SPW59333.2023.00012).
- [20] M. Abadi et al., "Deep learning with differential privacy," in *Proc. ACM SIGSAC Conf. Comput. Commun. Security*, 2016, pp. 308–318.
- [21] G. Xu, H. Li, Y. Zhang, S. Xu, J. Ning, and R. H. Deng, "Privacy-preserving federated deep learning with irregular users," *IEEE Trans. Depend. Secure Comput.*, vol. 19, no. 2, pp. 1364–1381, Mar. 2022.
- [22] H. Lycklama, L. Burkhalter, A. Viand, N. Küchler, and A. Hithnawi, "RoFL: Robustness of secure federated learning," in *Proc. IEEE Symp. Secur. Privacy (SP)*, May 2023, pp. 453–476.
- [23] A. Yazdinejad, A. Dehghantanha, and G. Srivastava, "AP2FL: Auditable privacy-preserving federated learning framework for electronics in healthcare," *IEEE Trans. Consum. Electron.*, vol. 70, no. 1, pp. 2527–2535, Feb. 2024.
- [24] E. M. El Mhamdi, R. Guerraoui, and S. Rouault, "The hidden vulnerability of distributed learning in Byzantium," in *Proc. 35th Int. Conf. Mach. Learn.*, 2018, pp. 3521–3530.
- [25] S. Guo et al., "Byzantine-resilient decentralized stochastic gradient descent," *IEEE Trans. Circuits Syst. Video Technol.*, vol. 32, no. 6, pp. 4096–4106, Jun. 2022.
- [26] P. Mohassel and Y. Zhang, "SecureML: A system for scalable privacy-preserving machine learning," in *Proc. IEEE Symp. Security Privacy (SP)*, Sep. 2017, pp. 19–38.
- [27] Y. Lu, Z. Yu, and N. Suri, "Privacy-preserving decentralized federated learning over time-varying communication graph," *ACM Trans. Privacy Secur.*, vol. 26, no. 3, pp. 1–39, Aug. 2023.
- [28] C. Xie, K. Huang, P.-Y. Chen, and B. Li, "DBA: Distributed backdoor attacks against federated learning," in *Proc. Int. Conf. Learn. Represent.*, 2020.
- [29] V. Tolpegin, S. Truex, M. E. Gursoy, and L. Liu, "Data poisoning attacks against federated learning systems," in *Proc. Eur. Symp. Res. Comput. Secur. Cham, Switzerland: Springer*, 2020, pp. 480–501.
- [30] J. Bell et al., "ACORN: Input validation for secure aggregation," in *Proc. 32nd USENIX Secur. Symp. (USENIX Secur.)*, 2023, pp. 4805–4822.
- [31] M. Rathee, C. Shen, S. Wagh, and R. A. Popa, "ELSA: Secure aggregation for federated learning with malicious actors," in *Proc. IEEE Symp. Secur. Privacy (SP)*, May 2023, pp. 1961–1979.
- [32] S. Addanki, K. Garbe, E. Jaffe, R. Ostrovsky, and A. Polychroniadou, "Prio+: Privacy preserving aggregate statistics via Boolean shares," in *Proc. Int. Conf. Secur. Cryptogr. Netw. Cham, Switzerland: Springer*, 2022, pp. 516–539.
- [33] S. Shen, S. Tople, and P. Saxena, "AUROR: Defending against poisoning attacks in collaborative deep learning systems," in *Proc. 32nd Annu. Conf. Comput. Security Appl.*, 2016, pp. 508–519.
- [34] X. Cao, M. Fang, J. Liu, and N. Z. Gong, "FLTrust: Byzantine-robust federated learning via trust bootstrapping," 2020, *arXiv:2012.13995*.
- [35] Y. Fu, X. Liu, S. Sarkar, and T. Wu, "Gaussian mixture model with feature selection: An embedded approach," *Comput. Ind. Eng.*, vol. 152, Feb. 2021, Art. no. 107000.
- [36] Y. Hu, J. Zheng, S. Jiang, S. Yang, J. Zou, and R. Wang, "A Mahalanobis distance-based approach for dynamic multiobjective optimization with stochastic changes," *IEEE Trans. Evol. Comput.*, vol. 28, no. 1, pp. 238–251, Feb. 2024, doi: [10.1109/TEVC.2023.3253850](https://doi.org/10.1109/TEVC.2023.3253850).
- [37] F. Wei, P. Vijayakumar, N. Kumar, R. Zhang, and Q. Cheng, "Privacy-preserving implicit authentication protocol using cosine similarity for Internet of Things," *IEEE Internet Things J.*, vol. 8, no. 7, pp. 5599–5606, Apr. 2021.
- [38] J. Zhao, H. Zhu, F. Wang, R. Lu, and H. Li, "Efficient and privacy-preserving tree-based inference via additive homomorphic encryption," *Inf. Sci.*, vol. 650, Dec. 2023, Art. no. 119480.
- [39] (2023). *Availability With Redundancy*. Accessed: Mar. 28, 2023. [Online]. Available: <https://docs.aws.amazon.com/whitepapers/latest/availability-and-beyond-improving-resilience/availability-with-redundancy.html>
- [40] C. Jiang and Y. Pang, "Encrypted images-based reversible data hiding in Paillier cryptosystem," *Multimedia Tools Appl.*, vol. 79, nos. 1–2, pp. 693–711, Jan. 2020.
- [41] E.-M. El-Mhamdi, R. Guerraoui, and S. Rouault, "Distributed momentum for Byzantine-resilient learning," 2020, *arXiv:2003.00010*.
- [42] I. Goodfellow, Y. Bengio, and A. Courville, *Deep Learning*. Cambridge, MA, USA: MIT Press, 2016. [Online]. Available: <http://www.deeplearningbook.org>
- [43] S. J. Mohammed and D. B. Taha, "Paillier cryptosystem enhancement for homomorphic encryption technique," *Multimedia Tools Appl.*, vol. 83, no. 8, pp. 22567–22579, Aug. 2023.
- [44] *Paillier Cryptosystem*. Accessed: Jun. 2, 2016. [Online]. Available: <https://python-paillier.readthedocs.io/en/develop/>
- [45] Y. Huang et al., "Personalized cross-silo federated learning on non-IID data," in *Proc. AAAI Conf. Artif. Intell.*, 2021, pp. 7865–7873.
- [46] X. Li, K. Huang, W. Yang, S. Wang, and Z. Zhang, "On the convergence of FedAvg on non-IID data," 2019, *arXiv:1907.02189*.